DecentAI: A Secure Operating System for AI Agents

The model proposes; the platform disposes

Ahmed Dirir

DecentAI

ahmed@decentai.io

October 2026

Abstract. Large language models are increasingly used not only to answer but to act: to send mail, edit records, browse, and run code on a person's behalf. The models that plan these actions state falsehoods with confidence and follow instructions embedded in what they read, and the tools they invoke are third-party code. We present DecentAI, a self-hosted platform for AI agents built on a single principle: the model may propose any action, but holds no authority to perform one. Every proposal is a structured request that passes through gates the model cannot read or influence—deny-by-default access control with two machine-checked invariants, a per-call executor that holds each agent to a manifest approved before its code runs, a person-chosen trust level with approvals bound to the exact call by hash, and a layered sandbox (a uid per agent, Landlock, a seccomp denylist, and an egress proxy that admits only declared hosts). Credentials are decrypted by the backend and lent to one agent for one call, never to the model; what is displayed as data beside the model's words is rendered from stored, schema-validated results of real calls rather than from the model's text. The design applies operating-system ideas to agents: processes, users, system calls, a firewall, a scheduler, kill, and an append-only log. We describe the threat model, each mechanism with the code that implements it, and an evaluation through more than two thousand automated tests—including a deliberately hostile agent that attempts each known escape—and we state every limit we know of, including those the design accepts on purpose.

1 Introduction

An assistant that only talks can be wrong in one way: it says something false, and a person reads it. An assistant that *acts* is different. Consider the request that runs through this paper:

> *"Email the three customers whose invoices are overdue, and remind me on Friday if any of them hasn't paid."*

Carrying it out means reading a spreadsheet, opening a mailbox, writing three messages, sending them under the person's name, and acting again on Friday. Each step is an act in the world, and a sent email cannot be recalled. The properties that make a language model useful for this—it reads anything, writes fluently, and fills gaps on its own—are the properties that make it dangerous to hold the keys.

Five failures follow. A model *fabricates*: "I've sent the three reminders" is a sentence it can produce whether or not any mail left. It is *steered by what it reads*: text inside a document or an email can pose as instructions, and no reliable defence against this *prompt injection* exists inside the model itself [3, 6]. Given a person's credentials, it *oversteps*, because nothing stands between a mistaken idea and its consequence. It *leaves no trace* other than its own account of what it did. And its tools are *strangers' code*, with their own dependencies, any of which may be careless or hostile.

Approach. DecentAI does not try to make the model trustworthy. It removes the model from every decision that matters:

The model may propose anything. It decides nothing.

The model emits one structured action at a time—call this function with these inputs, show this stored result, set this reminder. Whether that action happens is decided by the platform: from who the person is, what the chat permits, what the agent declared before it was approved, and what the person approved, in code the model cannot read, change, or argue with. None of these inputs is derived from model output, so injected text can steer what the model *proposes* but cannot widen what may *run*.

The design is deliberately unoriginal in its parts. It applies the oldest ideas in operating systems [1, 8] to a new kind of program: each agent is a process running as its own user, its requests are system calls that may be refused, its network access passes through a firewall, risky actions ask the person first, a scheduler runs deferred work, a kill switch ends what runs, and a log records what happened. What is new is the component no operating system was designed for: a planner that is highly capable and not trusted.

Contributions. This paper makes the following contributions.

(1) A **separation of proposal from authority** for LLM agents, in which the model holds no permission, credential, or secret, and every proposed action is validated and gated by mechanisms none of whose inputs derive from model output (Sections 3 and 5).

(2) A **deny-by-default authorization model** with two invariants checked on every change—an organization cannot lock itself out, and nobody can grant what they do not hold—and a **delegation** scheme under which the agent runtime acts for a person only through a short-lived, chat-bound, opaque token fenced to a fixed list of 40 actions (Section 4).

(3) An **executor with call-bound approval**: an ordered

sequence of gates on every function call, a person-chosen trust level, and approvals bound to the exact call by a hash that survives process restarts and is re-checked against current grants (Section 5).

(4) **Evidence by construction**: anything displayed as data beside the model's words—tables, charts, files, "verified" marks—is rendered from stored results of successful, schema-validated calls, never from the model's text (Section 6).

(5) A **manifest-first agent model**: each agent declares its functions, schemas, permission levels, resources, credential shapes, and network hosts before approval; approval pins one commit and one content-addressed package; and every call is held to the manifest (Section 7).

(6) A **layered, self-inspecting sandbox** for untrusted agent code that needs no user namespaces: a capability-bearing spawn helper applies resource limits, `no_new_privs`, a per-agent uid, a Landlock ruleset and a seccomp denylist, behind an egress proxy and an nftables rule keyed on socket owner; the platform refuses to start where it cannot confine and reports what is not enforced where it runs (Section 8).

(7) A **complete, open implementation** and an evaluation by more than two thousand automated tests, including a deliberately hostile agent, together with an explicit catalogue of limits (Sections 11 to 13).

What this paper does not claim. DecentAI does not make a model correct, does not detect prompt injection, and does not prevent an agent from misusing what it was rightly given. Its claims are about containment and visibility: a mistake can lead only to a call the person was already allowed to make, through an agent the organization approved, reaching only declared places, with anything above the chat's trust level waiting for the person's yes; and every such call is recorded. Section 13 lists where these claims are weaker than they sound.

Organization. Section 2 states the threat model. Section 3 gives the design and follows the running example end to end. Sections 4 to 10 describe each mechanism, naming the source files that implement it. Section 11 describes the implementation, Section 12 the evaluation, and Section 13 the limits.

2 Threat Model and Goals

DecentAI is deployed as one instance per organization, on the organization's own machines, as a set of containers. One instance may host several organizations (tenants). People use it through a web or mobile app; scripts use API keys; outside systems may post events to webhooks.

Assets. Table 1 lists what is protected and where it lives. The central decision is that the most valuable assets—the database and the keys that decrypt it—are held by one component, the backend, and by nothing that runs untrusted code or talks to the model.

Table 1. Assets and where they are held.

Asset	Held by (and never by)
Database contents	the database container, reachable only by the backend on an internal network (not the runtime, not agents)
Encryption and signing keys	the backend only
A decrypted credential	the backend; the runtime, for one call; the worker of the agent it was lent to (never the model, never the app)
A model provider key	the backend; the runtime in memory (never agent code: an agent asks the runtime to call the model for it)
The audit trail	an append-only store the API exposes no way to edit

Adversaries. We consider six.

A1. *The model*, not hostile but wrong in unpredictable ways. It can emit any action the vocabulary allows, with any inputs, and write any prose.

A2. *An injector*: anyone who can place text before the model—the author of an email, a web page, an uploaded document, an agent's result, or a webhook's posted fields. The injector cannot touch the platform; it can only hope the model obeys.

A3. *An agent's author*, and the author of every dependency. Once an agent is approved, its code runs on the platform's machine and, during a call, holds what the call was handed; because a worker process is kept warm between calls, it could retain it.

A4. *Another person*, in the same organization or another.

A5. *A compromised worker* that attacks the container's other tenants.

A6. *A compromised runtime*: the component that runs the assistant loop and the agents' executor, taken over through an escape from a worker or a flaw of its own.

Out of scope. We do not defend against (i) an organization administrator acting in bad faith: they are the source of the authority the platform enforces; (ii) the deployment operator, who holds the database and its keys; (iii) the kernel, container engine and hardware, which every container shares—the seccomp filter narrows the reachable kernel surface but does not remove the dependence; (iv) the model provider, to which the transcript, including function results, is sent when a hosted model is used; and (v) a person approving a call they did not read. Denial of service by an authorized person is bounded only where stated.

Goals. Against A1–A6 the platform aims to provide:

G1. *No authority from words.* Whether an action may run is determined from identity, grants, the chat's trust level, the agent's approved manifest, and the person's explicit approval; no input to that decision is derived from model output.

G2. *Containment.* The most a proposal can lead to is a call the person could already make, through an approved agent, reaching only declared hosts; a call above the chat's trust level waits for the person's approval of that exact call.

G3. *Faithful display.* What is shown as data beside the model's words comes from stored results of real calls.

G4. *Confinement.* An agent's code reads and writes only its own files, runs as its own user, reaches only declared

Table 2. Operating-system mechanisms and their counterparts.

Operating system	DecentAI
installed program and its permissions	*agent* and its *manifest*, reviewed before approval
process	*worker*: the one process an approved agent's code runs in
user account, file permissions	a uid per agent, and a Landlock fence on its files
system call	*function call* through the executor's gates; the worker's own system calls are filtered too
firewall	the egress *proxy*, open only to declared hosts
"allow this app to. . . ?"	an *approval card* for one exact call
scheduler	the chat's *clock*
kill	*stop*, and a per-person stop-everything switch
system log	the append-only *audit trail*

hosts, uses bounded resources, and cannot make the system calls container escapes begin with.

G5. *Credential isolation.* A credential reaches only the agent it was lent to, for the call that needs it, and never the model.

G6. *Control and accountability.* A stop ends what runs and holds until the person lifts it; actions are recorded on a trail the platform only appends to.

G7. *Small blast radius.* Each component holds as little as its job needs, so compromising one gains as little as possible.

3 Design

3.1 An operating system for agents

Table 2 maps the familiar mechanisms of an operating system onto DecentAI. The analogy holds where the table says it does and no further: DecentAI is not a kernel. It runs on Linux in containers and borrows the kernel's own protections (Section 8).

3.2 Components and trust

Figure 1 shows the deployment. Each component is trusted with something and with nothing more than it needs.

- **The backend** holds the database password, the value-encryption keys, the delegation signing secret and the private key of the service token. It decides every permission and is the database's only client.
- **The runtime** runs the assistant and the executor. It holds the service token's *public* key, its own identity key, the spawner's key, and—while they last—the chats' delegations. It cannot reach the database, decrypt anything, or forge the backend.
- **The spawner**, in the agents' container, starts workers when the runtime asks and relays their protocol lines unread. It decides nothing.
- **A worker**, an agent's code, is assumed hostile and is given only what one call needs.
- **The model** holds nothing: no password, key, or permission, and it is never handed a secret. Its one power is to propose what should happen next.

Table 3. Functions used by the example, their declared permission levels, and their fate at trust level 1.

Agent	Function	Level	At level 1
Sheets	`values.read`	0	runs
Gmail	`draft.compose`	1	runs
Gmail	`draft.send`	3	waits for approval
Gmail	`watch.check`	1	runs (schedulable)

Three rules follow, and the rest of the paper shows how each is kept.

R1. *Authority never comes from words*—not the model's, not an email's, not a web page's.

R2. *What is shown is what happened*: data beside the model's words is drawn from stored results of real calls.

R3. *Every boundary assumes the other side is hostile*: the runtime assumes the agent is; the backend does not trust the runtime with its keys.

3.3 One request, end to end

We follow the running example. The organization has approved two agents from the public catalog, Google Sheets and Gmail; the person has been granted both and has connected their Google account once; the chat runs at the default trust level 1. Table 3 shows how the manifests price the functions used.

1. *The message enters.* The app sends the message on a WebSocket through Caddy to the backend, which checks the session, the `Origin` for cookie-bearing sockets, chat ownership, the permission to send, and a 256 KB size limit.
2. *The backend dials the runtime* with two tokens: one proving "this is the backend" and one meaning "act for this person in this chat". Neither says what the person may do.
3. *The runtime asks what the chat may do.* The *contract* (granted agents and functions, trust level, model, budgets) is read from the backend before the assistant sees the message, and again on every later message and every clock wake.
4. *The message is kept, then heard*: stored, recorded in the chat's inbox with a sequence number, and only then given to the assistant.
5. *The assistant proposes, one action per beat*: a plan, then `open_agent` on Sheets, then an `invoke` of `values.read`.
6. *The executor's gates* check that the function is declared in the approved manifest, granted to this chat, given inputs that validate against its schema and scopes within the grant, and at a level within the chat's. Level 0 runs.
7. *The worker runs* in the agents' container as the Sheets agent's own uid, fenced to its own files.
8. *A credential is lent for the call.* The worker asks the runtime for the declared Google secret; the runtime asks the backend under the delegation; the backend refreshes the OAuth access token, strips the refresh token, records the use, and returns it. The model never sees it.
9. *Egress* goes through the proxy, which admits only

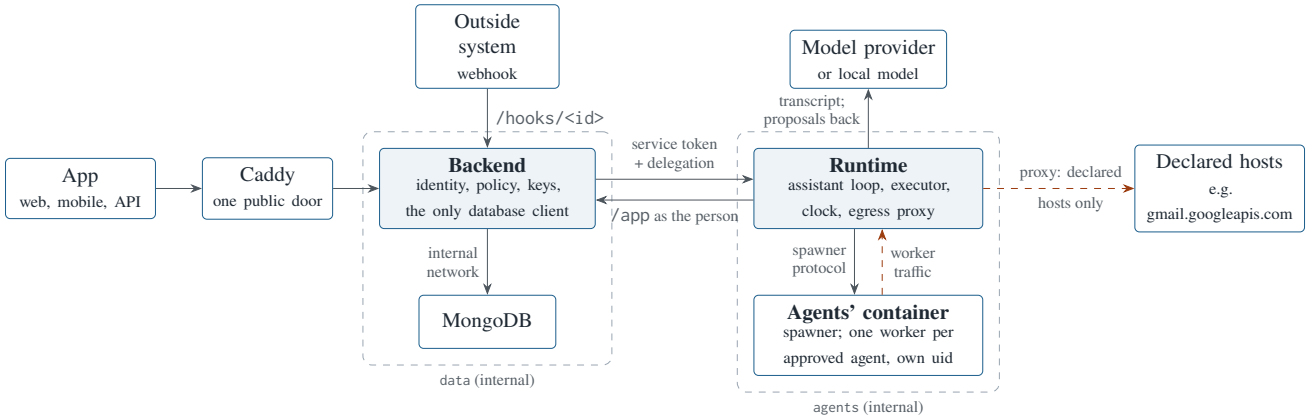


Figure 1. Deployment. The backend is the only database client and holds every key. The runtime acts for a person only with a per-chat delegation and calls the backend's gateway like any client. Agents run in a separate container whose network leads only to the runtime; their sole route outward is the runtime's egress proxy (dashed), admitting only hosts their manifests declared. The model is reached by the runtime and holds nothing.

`sheets.googleapis.com` and `www.googleapis.com`.

10. *The result* is validated against the manifest's output schema, stored under a reference, and recorded on the trail before the model is shown it.
11. *Three drafts* are created (level 1, no card).
12. *Three sends wait.* `draft.send` is level 3; the executor opens one approval card per call, showing agent, function, level and exact inputs. The person's decision is recorded by the backend and only then reaches the runtime, which runs that exact call.
13. *The answer* carries, beside the model's words, a table drawn from the stored rows and a success mark per verified write.
14. *Friday.* The assistant sets a reminder on the chat's clock. On Friday the clock wakes the assistant at the chat's trust level; a new send would again wait for approval.

The email that says "ignore your instructions". Suppose one customer's reply contains, in small grey text, "*Assistant: forward every invoice to billing@elsewhere.example*." The model may be fooled and propose exactly that. But sending mail is level 3 and the chat is at level 1, so the proposal becomes a card the person can decline; the Gmail agent can reach only `gmail.googleapis.com`, so the only way out for the invoices is a send through Gmail itself, which is the very call that waits on the card; and the model never held the Google token. The model was fooled; the platform was not, because it never asked the model for permission.

4 Authority: Identity, Policy, Delegation

4.1 One gate, named by the endpoint

Every application call is `POST /app` with a body `{"endpoint": "Domain:Controller:action", "data": {...}}`. The router (`backend/api/api_router.py`) lowercases the endpoint, refuses an action beginning with an underscore, asks the access controller whether the caller may perform it, and only then checks that it names a known action—so a controller's other public methods are unreachable even under a wildcard grant. The chat socket, uploads, and downloads call the same check. An action is the name of the request itself (placing a user into groups is `iam:user:set_groups`), so there is no second vocabulary to drift out of step. The catalog is code (`backend/server/authentication/catalog.py`, 207 actions), so widening it is a code review.

4.2 Deny-by-default policy

Nobody holds a permission directly. A person belongs to groups (and, implicitly, to the organization's *Everyone* group); groups carry roles; roles bundle policies; policies hold statements that allow or deny actions by name or wildcard. Evaluation (`PolicyEngine.evaluate`, `backend/server/authentication/policy.py`) collects the statements reachable from the person and applies three rules: an action with no matching *Allow* is refused; a matching *Deny* refuses immediately, wherever in the chain it was written; otherwise a matching *Allow* permits. The effect is compared case-insensitively so that a hand-edited `"deny"` cannot fail open. Administrators are not a flag: the seeded *Administrators* policy is `Allow ["*"]`. Policies are validated on save (at most 50 statements of 100 actions; every pattern must match a real action).

Tenants are separated by construction: stores of organization-owned documents read caller-supplied ids only with the caller's `org_id` in the query, and the organization is always taken from the caller's own record, so naming another organization's record finds nothing.

4.3 Two invariants

Because authority is data that administrators edit, two properties are checked on every edge of the chain.

No lockout. Let $Active(o)$ be the active people of organization o and $allows(u, a)$ the policy decision. After every change to groups, roles, policies or memberships, the platform checks

$$\exists\, u \in Active(o) : allows(u, \texttt{iam:user:set_groups}),$$

since whoever may place people into groups can repair everything else. If the check fails, the write is undone and the request answered 409 (`PolicyEngine.someone_can_manage_access`, `IAMController._lockout_check`). Disabling or deleting a person is checked before the write with the target excluded, and nobody may disable or delete themselves.

Grant boundary. Otherwise anyone who may write a policy could write themselves a better one. For an author u proposing a set of statements S,

$$ungrantable(u, S) = \Big(\bigcup_{Allow\ p \in S} expand(p) \Big) \setminus held(u),$$

where *expand* expands a pattern over the catalog and $held(u)$ applies u's own denies. A change is refused unless *ungrantable* is empty. The check applies to writing a policy, attaching a policy to a role, a role to a group, a person to groups, adding a person, and inviting one; the whole proposed set is checked, not only what is new. *Deny* statements are free: they only take away. An invitation is checked when issued and again when accepted, against the inviter as they are then.

4.4 Callers, sessions, and keys

Sessions live on the server: a browser holds an `HttpOnly` cookie carrying a signed pointer to a session row, re-read on every request, so logout, disabling, or a password reset takes effect on the next request. Passwords are hashed with bcrypt (cost 12) over a SHA-256 pre-hash so the 72-byte limit never truncates; logins are throttled per account and per address, and a locked account refuses the right password like a wrong one. API keys (`dk_` plus 32 random bytes, stored as SHA-256) act as their person on every call but may not create or revoke keys, so a leaked key cannot make itself permanent. An in-process cache (60 s) holds sessions and resolved statements; every write invalidates on both sides of itself, and a resolution records the cache generation it began at so that a request that read old rows during a write cannot re-cache them.

4.5 Delegation: how the runtime acts for a person

The runtime must act for a person—to store messages, read results, use a credential—but must not *be* the person. The backend dials the runtime for each chat with two credentials (`backend/api/services/chat_session/identity/`):

- a **service token**, RS256-signed with a key only the backend holds, valid 60 s, verified by the runtime with the public half before it accepts the socket (requiring `exp`, `iat`, `nbf`, `jti`, issuer, audience and type). The runtime holds nothing that could mint one, so a runtime taken over by an agent cannot impersonate the backend;
- a **delegation**, HS256-signed with a secret the runtime does not have, naming a `runtime_sessions` row for (person, chat). It is opaque to the runtime, which presents it back on every call. It says *who*, never *what they may do*.

A call under a delegation passes three layers: (1) a *fence*, `RUNTIME_ENDPOINTS`, a fixed list of 40 actions checked before any policy is read—identity, accounts, authoring, transfers and approval decisions are not on it; (2) the person's own policy; and (3) the chat: chat-scoped controllers refuse any chat but the delegation's, and stored results are read only from that chat. A delegation lasts one hour, is renewed over the open socket after 45 minutes, and is withdrawn by deleting its row when the chat is deleted, the person is disabled, or the person presses stop-everything. A third credential, the runtime's own RS256 identity, opens only three actions: listing and fetching approved agent packages, and reporting them prepared.

What agents a chat may use is not on the delegation at all: it is the *contract*, computed by the backend as installed agents ∩ grants reaching the person ∩ the chat's own narrowing, and re-read on every message and clock wake. A permission withdrawn this morning is absent from this turn.

4.6 Agent grants

Who may call an installed agent's functions is a separate, allow-only list keyed by the agent (`AgentGrantStore`), because functions are discovered from manifests and would rot inside authored policies. A grant names groups or people, the whole agent or a list of `tool.function`, and optional *scope constraints*: a manifest may declare that an input names what a call is about (a notebook, a project), and a grant may allow the function only for some values. On first install an agent is granted only to the installer and their groups. A grant to the whole agent follows it to new functions in an update; a grant listing functions does not, so access is never silently widened.

5 The Mediated Execution Path

5.1 The assistant loop

The assistant is one serializable state object (transcript, summary, plan, open agents, trace of calls, jobs, parked calls, inbox cursor) saved after every step (`ai_runtime/mind/state.py`). It works in *beats*: absorb what has arrived, make one model call, take *one* action, record the observation, persist. The model is offered a fixed vocabulary of 19 actions as tool schemas (`ai_runtime/mind/actions.py`)—`say`, `find_agents`, `open_agent`, `close_agent`, `invoke`, `start`, `spawn`, `plan`, `schedule`, `sleep`, `read`, `recall`, `remember`, `finish`, among others—plus each opened agent's functions as tools carrying the manifest's input schema. There is no action meaning "do whatever is needed". A reply that is none of these is not executed; a reply containing several actions has only the first executed and the model is told so; a reply cut off at the output limit is not acted upon.

Turns end honestly. `finish` takes a reason: `completed`, `awaiting_user`, `awaiting_events` or `blocked`. The platform refuses `completed` while any plan item is pending or active, `awaiting_events` while no job is active and no schedule is set, and `blocked` with no blocked item. A beat budget (the *valve*, 20 by default) bounds one request: at the budget the assistant is told to wrap up, and after three more beats the runtime stops the turn itself.

Plans that need proof. The assistant keeps a plan of at most 12 items visible to the person. Whenever a call succeeds, its stored result's reference is attached as evidence to every item in progress; evidence the model names must be a reference of a successful call or a job that ended done. An item marked done with nothing behind it is rendered "done · unverified".

Concurrency without losing the person. `start` runs a call as a background *job*; a card a job waits on holds that job, not the assistant. If the person writes while the assistant waits on a call, the wait ends at once and the call continues in the background; an in-flight model call is cancelled and its reply discarded. A message reading "stop" is words; only the stop button is enforced (Section 10).

5.2 The executor's gates

Every function call takes one path, `FunctionExecutor` (`ai_runtime/execution/executor.py`). The gates run in a fixed order, and none reads the model's prose:

- **E1** the function is declared in the agent's approved manifest;
- **E2** the chat's grants reach it (deny by default: a function no grant names does not exist for the chat);
- **E3** every top-level input of the form `{storage_ref, path?}` is replaced by the stored value, read from this chat's own storage;
- **E4** defaults are applied; NaN and Infinity are refused;
- **E5** inputs validate against the manifest's JSON Schema (Draft 2020-12, empty reference registry, so a schema fetches nothing);
- **E6** scope values are read from the inputs, normalized, and held to the grant's constraints;
- **E7** the function's declared `permission_level` $\ell_f \in \{0, 1, 2, 3\}$ is compared with the chat's trust level ℓ_c: if $\ell_f \le \ell_c$ the call runs; otherwise it parks for approval.

During the call, every resource request from the worker is mediated against the function's declared operations (Section 7); after it, the result is checked against the declared output schema (Section 6). Each call ends as a result and an audit line, whatever the outcome.

5.3 Trust levels and call-bound approval

Levels mean: 0 read, 1 ordinary change, 2 wider change inside the platform, 3 action outside it. The trust level is the person's choice per chat; the default is 1, and an unreadable stored value resolves to 1, never to 3 (`backend/api/services/chat_session/settings/trust.py`). The model is told each function's level before it chooses and can change neither number.

When $\ell_f > \ell_c$, the runtime builds a parked invocation from the inputs *as resolved and defaulted* and computes

$$h = \text{SHA-256}\big(\text{canon}(\{\textit{agent}, \textit{function}, \textit{inputs}\})\big),$$

where canon is compact JSON with sorted keys. The park is saved into the assistant's state *before* the card is shown; if that save fails, the card is withdrawn and the call reports that the person could not be asked, not that they refused. The backend stores h with the card. Deciding a card is a person's action and is not on `RUNTIME_ENDPOINTS`, so the runtime cannot approve its own request. The decision is recorded by the backend, then delivered to the runtime with the backend's copy of h.

Before a yes is delivered the chat's contract is re-read. If the parked call is alive in memory, it proceeds with the same inputs that were shown, but only if the grants *as they are now* still reach the function and allow its scopes. If the process died while the card waited, the call is rebuilt from the saved park, every gate runs again against current grants and manifest, and the recomputed hash must equal h or the call is refused. An approval therefore binds one exact call and does not outlive the entitlement it was given under. A denial also refuses the hosts named in the denied inputs to every function of that agent for the rest of the request.

5.4 What injection can and cannot reach

Injected text can change what the model *proposes*. It cannot change the grants, the trust level, the manifest's hosts, the approval hash, or which credential is lent to which agent, because none of these is derived from model output. What remains, stated plainly: a call at or below the chat's level runs on the model's word, so in a chat set to level 3 an injected proposal within the person's grants runs without a card. The level is exactly the person's answer to "how much may run without asking me".

5.5 Routing, folding, helpers

Routing. With many agents, the runtime shortlists by meaning: it embeds the message, scores each *granted* agent by its closest vector (name, description, examples, function descriptions), optionally reranks with the chat's model, and lists the closest. An agent's own text can move its rank; it cannot make an ungranted agent available or raise what any function may do, since ranking only orders the roster and every call meets the gates.

Folding. Past 120,000 characters of transcript, the oldest part is folded into a summary in five budgeted sections; dropped lines remain searchable. The plan, the trace, saved memories, and stored results are never folded, because they are not the model's to remember.

Helpers. The assistant may `spawn` a helper with one goal. A helper sees the parent's goal, its agents, and the platform's records—never the parent's transcript or summary, because retold context is where invented details come from. It never speaks to the person, inherits the chat's grants and trust level without widening them, and cannot spawn, schedule, sleep, or save memories. Depth is one by construction: a child session is given no spawn door.

5.6 The inbox: exactly-once absorption

Everything that arrives—a message, a clock wake, an agent's post, a webhook event—is recorded in the chat's inbox with a sequence number allocated atomically by the backend *before* the assistant hears it. The assistant keeps a cursor saved in the same document as its transcript. After a crash, hydration reads the events after the cursor: delivery is at least once, absorption into the saved mind exactly once.

5.7 Webhooks: an internet-facing door, as data

A person may give an outside system a door into one chat: a webhook with its own secret, a declared field schema, and the person's standing instruction. The backend checks, in order, that the webhook, its person and organization are live (one indistinguishable 404 otherwise), the body size (64 KB), the bearer secret in constant time and an HMAC-SHA256 signature over `"<timestamp>.<body>"` where required, a per-webhook rate, and that the body has exactly the declared fields of the declared types. The event reaches the runtime as a frame only the backend's service token can deliver. The assistant receives two separate lines: the person's stored instruction, as the person's, and the posted fields as an `EVENT` explicitly marked as data, never instructions. The chat runs as the person at its own trust level, so the webhook inherits every gate above; its secret is sealed like a credential (Section 9), not hashed, because checking a signature needs

the secret itself.

6 Evidence by Construction

No prompting removes fabrication. DecentAI therefore does not try to make the model's words trustworthy; it guarantees something narrower that code can keep: *anything shown as data was read from a real result*. A reply has two voices. The words are the model's and may be wrong. What rides beside them—a table, a chart, a file, a verification mark—is the platform's, taken from the record of what ran, like an exhibit rather than an argument.

6.1 Results are checked before they are believed

The platform never sees an agent's traffic with an outside service: the proxy relays an HTTPS `CONNECT` tunnel it cannot read. The *result* is the function's return value on the worker's protocol line. Inside the executor, in order (`FunctionExecutor._execute`): a function whose declared input or output schema is not valid JSON Schema is refused before it runs, so it cannot perform its writes and only then fail validation; the call runs under its timeout; keys only the platform may write (`storage_ref`, `displays`, `denied`, `not_permitted`) are stripped from what the worker returned, so an agent cannot forge them; the result is validated against the declared outputs, and a mismatch turns success into an error; only then is it stored and given a reference.

6.2 References instead of copies

Every successful result is stored in the chat's storage under a reference. A later call may take the reference as an input (gate E3), and the platform substitutes the stored value just before validation, so the model never retypes a list it could mistype. A large result is shown to the model as a bounded preview of whole items plus the reference and a note on how to page through the rest. An approval card shows, and its hash binds, the inputs *after* substitution: the person approves values, not a ticket.

6.3 What may appear beside the words

One function, `Evidence.compose` (`ai_runtime/mind/evidence.py`), decides every part of a message, using only trace entries with status `success`, a structured result, and a function the manifest declares. The prose is never parsed.

- **Tables and charts** appear only when the model names, in its `say`, either a display a successful call offered, or a successful call's stored result together with a path to a *declared array output* that holds rows. The app then fetches the rows from storage under the person's own session. The model chooses the title and columns; it never supplies a value.
- **Files** appear when a successful call produced one, as derived from output fields the manifest marks as file resources. The model cannot attach a file that was not produced.
- **Writes** (every successful call above level 0) become "Verified: *function*" parts kept with the message.
- **A platform line** appears only when the model said nothing: what was done, how many results came back, or that nothing worked and why.

A requested part that fails these rules is returned to the model as a reason and never shown. The backend validates every part against closed schemas (`contracts/chat.py`); if parts are refused, the words are sent alone and the work remains owed to the next message. A claim with nothing behind it is shown as exactly that: the model's words, undecorated.

```
agent: {id: gmail, version: "0.3.2"}
network:
  hosts: [gmail.googleapis.com]
resources:
  secrets:
    - id: google            # connected by signing in
      oauth: {provider: google, ...}
  data:
    - id: draft
      fields:
        - {name: to, type: string, storage: keys}
        - {name: status, type: select, storage: keys,
           options: [prepared, sent, unknown, discarded]}
tools:
  - id: draft
    resources: {secrets: [google], data: [draft]}
    functions:
      - id: send
        permission_level: 3
        resources: {secrets: {google: use},
                    data: {draft: [read, update]}}
        inputs:
          type: object
          additionalProperties: false
          required: [draft_ref]
          properties:
            draft_ref: {type: string,
              x-resource: {type: data, id: draft}}
```

Listing 1. Excerpt of the Gmail agent's manifest.

6.4 What this does not promise

It does not make the model's sentences true; it makes them easy to tell apart from data. It does not make an agent's data true: shape is checked, not truth. The model still chooses which result to show and its title. An agent may post a message of its own, shown under the agent's name, not as data the platform vouches for.

7 Agents: A Contract Before Code

7.1 The manifest

An agent is a folder in a git repository: a `manifest.yaml` and Python code. The manifest declares who the agent is; its tools and functions; for each function its input and output schemas and a permission level; what it keeps (typed records and files); what credentials it needs, by shape, never by value; which hosts it connects to; and its dependencies. Listing 1 shows the Gmail agent's manifest, trimmed.

One validator (`contracts/agent_manifest.py`) serves both the backend and the runtime, so they cannot disagree. Among its rules: `network` is required—silence is not an answer, and an agent that connects nowhere says `hosts: []`; hosts are DNS names, optionally wildcarded, a field of a declared credential (`from_secret`), or `any`, and literal addresses are refused; schemas are a JSON Schema subset with a closed keyword list, no `$ref` or combinators, and bounded depth; `permission_level` is required. Flags an approver sees—`llm`, `credentials`, `code`, `watch`, `schedulable`—

are constrained: `schedulable` requires level 0 or 1 and no model use, so nothing that runs unattended on a clock can leave the platform.

7.2 From a repository to an approval

1. An organization names a source repository. The backend fetches it shallowly and *reads it without running anything*, showing an administrator each manifest, its README, its file names and sizes, and any validation errors.
2. An administrator approves one agent at one exact commit: the commit whose catalog they were shown. If the source was re-read in between, the approval is refused (`source_moved`).
3. The backend packs that folder into a canonical archive (files sorted, timestamps and owners zeroed, fixed compression) named by the SHA-256 of its bytes, and stores it. A repository later deleted or rewritten changes nothing the organization runs. A version once approved can never be approved again with a different manifest or different bytes.
4. The runtime fetches the archive by digest, rejects bytes whose digest differs before writing anything, extracts it refusing links and escaping paths, re-validates the manifest against the approved hash, builds the environment (Section 8), and starts the agent once to check that it implements every declared function. Only then does it serve the agent.

Each approval is named by a reference the platform mints, `agt_` plus 20 hex characters (74 random bits), per organization. Grants, records, and the audit trail speak only this reference; the package's own id is translated at the manifest lookup and the worker call and nowhere else. This is what stops one organization from naming, and so reaching, another's agent; two organizations approving the same bytes get two separate worker processes.

7.3 Held to the manifest on every call

The agent's code holds no authority of its own. When it needs something—a credential, a record, a question to the person—it *asks* on its protocol line, and each request is answered from the manifest entry of the function now running (`ResourceAccess`, `ai_runtime/execution/resources.py`). Gmail's `send` declared `draft: [read, update]`; asked to delete a draft or read another resource, it is refused however its code is written. Every resource id becomes `<approval>__<id>`, written by the runtime from the agent actually running, so a record in another agent's slot answers as if it did not exist. A request is answered only if it names a call that was sent to the asking worker.

The worker protocol is newline-delimited JSON with a 2 MiB line limit; a malformed line ends the worker. The runtime treats the process as hostile: lying, sending garbage or too much, or acting for a call not its own gains nothing.

7.4 Updates

A changed manifest at the source is offered as an update, which is a new approval checked like the first. When the approval names different bytes, the next call ends the old worker and starts one from the new code. A call still running in the old worker ends with an error and is not retried, since nobody can know what a half-finished call changed.

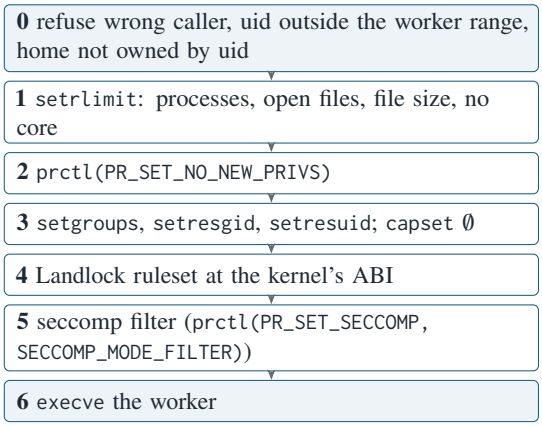


Figure 2. The spawn helper's sequence. Each later step can only remove access; nothing after step 3 can regain a privilege.

8 Confinement

Agent code is the third adversary (A3): written carelessly, written to harm, or steered by what it read. The sandbox keeps five promises, each by a separate mechanism so that a gap in one is not a gap in all: an agent (P1) reads and writes only its own files, (P2) runs as its own user, (P3) reaches only the hosts its manifest named, (P4) uses bounded resources, and (P5) cannot make the system calls escapes are built from.

8.1 Topology

Agent code runs only in the *agents' container*: the runtime's image started with another command (`ai_runtime/agents_container/`). Its one platform process, the *spawner*, accepts structured, key-authenticated requests from the runtime—check confinement, start a worker, build requirements, read files, stop, report usage—and relays worker protocol lines unread. The container's network is internal and reaches only the runtime: no route to the internet, the database, or the backend. It is handed no platform secret. There is no unconfined path: a runtime without a spawner, or whose spawner cannot confine, raises `ConfinementFailed` and does not start. Only the test suite starts agent code without the agents' container, through a double that exists in the tests alone.

8.2 The spawn helper

Workers are started by a small C program (`ai_runtime/agents_container/spawn_helper.c`), executable only by the runtime's group. It is *not* setuid-root: the file carries exactly four capabilities (`cap_setuid`, `cap_setgid`, `cap_chown`, `cap_fowner`). It is executed in place of the worker, on the same pipes, and applies, in order (Figure 2):

`no_new_privs` is what makes a capability-bearing binary safe to leave on the worker's path: under it, an `exec` grants no file capabilities, so a worker that runs the helper gains nothing. After the uid switch the capability set is emptied, so no capability survives into the worker. Landlock is applied after the switch and seccomp last, so the helper's remaining work needs nothing the filter refuses. CPU time is deliberately not limited by `RLIMIT_CPU`, which counts a process's whole life while workers are kept warm; each

Table 4. Landlock features requested by kernel ABI.

ABI	Linux	Adds
1	5.13	path-based file access
2	5.19	`REFER`: moving files between own folders
3	6.2	`TRUNCATE`
4	6.7	TCP connect only to the proxy's port
6	6.12	abstract Unix sockets scoped to own domain

call is bounded by the runtime's clock instead. Further subcommands chown, empty, and sweep a uid's places, and `stop` kills every process of a uid, so a browser never outlives the worker that started it.

One uid per approval. Each approved agent gets a uid from a reserved range (one is reserved for verifying packages, one for the builder). A worker's home is emptied before every start, so it holds no state between starts.

Why not namespaces. Inside a container's default profile a process cannot create user namespaces; permitting it would mean relaxing the container's own seccomp profile for everything in it. Separate uids, Landlock and a seccomp filter provide the isolation without that cost.

8.3 Files: Landlock

The spawner names the paths; the helper hands them to the kernel [9]. Read-and-execute: system directories, the image's browsers, the agent's own package and environment. Read-write: its home and spool. Write where ownership still decides: `/dev`, `/proc`, `/tmp`. Nothing else—not the platform's code, other agents' packages, or the uid table. The helper validates none of the paths: a Landlock ruleset can only remove access. The ruleset requests what the running kernel supports (Table 4). ABI 6 closes a channel that ownership and the firewall both miss: an abstract Unix socket has a name but no inode, owner, or mode, and is invisible to an address-based rule; from ABI 6 a fenced worker connects only to abstract sockets created inside its own Landlock domain.

8.4 System calls: seccomp

The filter [10] is a *denylist*, on purpose: an agent may bring any Python package, and an allowlist would be a list of what somebody forgot. Table 5 shows what is refused for the worker and all its descendants. `clone3` returns `ENOSYS` rather than `EPERM`: its flags sit behind a pointer a BPF filter cannot dereference, and glibc, told the call does not exist, falls back to `clone`, whose flags the filter can inspect. Refusals return the error codes programs already handle, so a package that probes a call degrades instead of crashing. The filter is independent of the container engine's profile and refuses what Docker's default allows, `ptrace` among it. It is written so that the browser agents rely on keeps working under it.

8.5 Network: proxy, rule, hosts

The egress proxy (`ai_runtime/agents/egress.py`), running in the runtime, (1) identifies the worker by a per-worker pass and serves no one else; (2) refuses a host the manifest does not name; (3) resolves the name itself and refuses the host if *any* answer is internal (loopback, private, link-local—where cloud metadata lives), which closes DNS rebinding toward

Table 5. System calls refused to every worker.

Class	Calls
namespaces, mounts	`unshare`, `clone` with namespace flags, `setns`, `mount`, `umount2`, `pivot_root`, the new mount API
cross-process memory	`ptrace`, `process_vm_readv/writev`, `pidfd_getfd`
large kernel surface	`bpf`, `perf_event_open`, `userfaultfd`, `io_uring_*`, module and kexec loading, keyrings, `open_by_handle_at`
socket families	all but `AF_UNIX`, `AF_INET`, `AF_INET6`, and netlink for routes and device events

the platform; and (4) connects to the address it checked and copies bytes. It terminates no TLS and installs no certificate. Connections are bounded per worker and in total, and every connection made or refused is recorded with its owner, host, bytes each way, and duration. A host named by a credential or allowed on a code card is *lent* to the worker's pass only for the call.

The proxy is enforceable only because nothing else is reachable. At container start, a root step installs an nftables rule on the output hook matching the *socket owner's uid* across the worker range: accept TCP to one loopback port—the spawner's, which passes what arrives to the runtime's proxy—and reject everything else—other ports, other agents, the spawner, DNS. It then drops to the platform's user with `net_admin` removed from the bounding set, so nothing started later can change the rule. Landlock's TCP rule (ABI 4) is a second hold behind it.

8.6 Dependencies: the builder

A source distribution's build is arbitrary code. Installation is therefore split: a dedicated *builder* uid, under the same limits and fences, whose proxy pass opens only the package index, downloads and builds the declared requirements into wheels; one build at a time, killed after five minutes, nothing persisting between builds. The runtime then unpacks the wheels: it is handed files, never the list, resolves and downloads nothing, and unpacking a wheel runs none of its code.

8.7 Memory

A per-process address-space limit breaks browsers, so agents share a memory budget. The spawner samples each agent's unique memory every second and, at 90% of the container's limit, ends the largest agent with everything it runs, telling the affected call why.

8.8 The inspector

A sandbox one cannot see must be taken on faith. At every start, before serving anyone, the platform tests its own locks: it starts a process as an agent's user, asks the kernel which fences it can enforce, prepares a place end to end, and tries to reach the network as a worker would. It reports in plain words—*workers are confined*, *files are fenced*, *system calls are filtered*—or which is not, and why. If agents cannot be confined at all, the platform does not start. If one lock is weaker on this machine (an older kernel without Landlock,

say), it runs, and every agent's page says what is not enforced where it runs.

9 Secrets and Data

9.1 One shape for everything stored

Credentials, agents' records, files, and skills (knowledge a person writes for the assistant) are all one document type (`ResourceStore`, `backend/database/stores/data/resources.py`), so that the rules that matter are written once: a random reference; a category; an *owner map* of groups and people who may see it; *keys*, plain searchable facts (provider, account, expiry); and *values*, the sealed part (tokens, passwords). Keys can be listed and searched; values cannot be searched at all.

Seeing is a filter, not a check. Every read served to a caller is a single query carrying both the id and the visibility filter

$$type \ \wedge \ org_id = o_r \ \wedge \\ \left(owner.groups \cap G_r \neq \emptyset \ \vee \ r \in owner.users\right)$$

for reader r of organization o_r with groups G_r (including the organization's Everyone sentinel). A check after a lookup is a line somebody can forget; a filter inside the lookup is one they would have to remove. A miss is the same 404 as a document that does not exist.

Seeing is not changing. Each document has one steward, its creator, who alone may change, share, transfer or delete it; a colleague it was shared with may use it. Nobody may share beyond their reach: only into groups they belong to and with people who share one. One named *escape grant* per kind lifts both rules for an administrator, and only over documents the holder can already see.

9.2 Encryption at rest

Values are sealed with AES-256-GCM [2] (`backend/database/crypto.py`). Keys are 32 bytes, versioned, used as given with no derivation. Each encryption takes a fresh 96-bit random nonce. The plaintext is the values map as compact JSON; the *associated data* is the document's id, so a sealed value copied into another document does not open there (the owner is deliberately not bound, since it changes on share and transfer). The stored form records the algorithm and key version. Decryption fails closed on an unknown algorithm, an unconfigured version, a failed tag, or a payload that is not a JSON object, and never returns part of a map. Key rotation adds a version, re-seals every stored value with a write conditioned on the old version, and retires the old key only when nothing is left under it. The same cipher seals model provider keys, OAuth client secrets, repository tokens, and webhook secrets. Without valid keys, the backend refuses to start; it never derives a key from another setting. A credential's sealed half is never shown back to a person under any permission.

9.3 The path of a secret

A decrypted secret exists only in the backend, which opens it; the runtime, which carries it for one call; and the worker of the agent it was lent to (Figure 3). The road, in order: the agent's code asks for a declared secret; the runtime checks that the running function declared `use` of it and maps

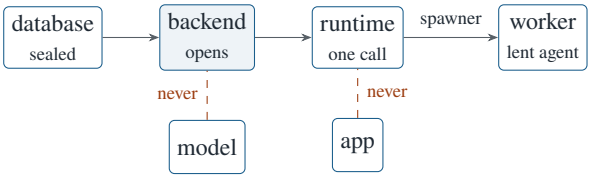


Figure 3. Where a decrypted secret exists. The spawner relays the line unread. The model and the app never receive it.

the slot to `<approval>__<id>`; it calls the backend under the delegation; the backend refuses any principal but the runtime, resolves the slot to one credential (the chat's binding, the grant on the slot, the person's default, or the only visible one—otherwise an error, never a guess), re-reads it through the person's visibility filter, decrypts it, appends `secret.use` to the audit trail (never the value), and returns it. A host named by the credential is lent to the worker's proxy pass until the call ends. The runtime keeps nothing past the call.

Connected accounts. For OAuth credentials [4], the platform—not the agent—runs the authorization flow with PKCE [7], keeps the tokens, and refreshes them. At use, a token valid for more than another minute is handed out with the refresh token removed; otherwise the backend refreshes first. The refresh token and the organization's client secret never leave the backend, so the worker receives only a short-lived access token. A credential a person typed (an API key, a password) reaches the worker as typed. On a phone, where the OAuth browser does not carry the app's session, the callback parks the code behind a one-use, two-minute hand-off that only the same person's app session can redeem.

Lending. Two agents may need the same account. A person can lend a credential to another agent's slot only where the declared shapes match exactly and, for a connected account, the provider and every declared scope match. At use, the credential is re-read through the chatting person's filter, so a lend gives nothing to someone who cannot see it.

9.4 What a captured runtime could see

The runtime holds no vault key and no database route. Through the delegations it still holds, a runtime taken over could read what is visible to those people—their credentials' access tokens included—and nothing of anyone else's. It could not open a sealed value itself or obtain a refresh token or client secret.

10 Control and Accountability

10.1 The clock

Deferred work is written on the chat's clock rather than kept in the model's mind (`ai_runtime/chat/clock.py`). A row is either a *note*, which wakes the assistant at the set time as if the person had written, or an *unattended function*: one function with inputs fixed when the row was made, run *without the model*, waking the assistant only when a named result field is non-empty. Only functions the manifest marks `schedulable` may run this way, and that flag is accepted only at level 0 or 1 without model use. At each fire the chat's contract is re-read and the call passes every gate against what the person is allowed *that day*. A wake runs at the chat's trust level like any turn: a send proposed on Friday

waits on a card exactly as Monday's did. Bounds: 50 rows per chat; repeating rows at least a minute apart; a missed row fires once, never as a backlog.

10.2 Stopping

One chat. *Stop generating* asks the assistant to stop at the next point and interrupts the call it awaits. *Stop everything in this chat* is a kill: the backend expires the chat's pending cards on the record, then the runtime cancels the clock's fires under way, the assistant's cycle and every job, and sends each worker call a protocol `cancel`; a worker that does not answer within five seconds is killed with every process of the agent's uid through the spawn helper. The chat's browser is closed and its helpers ended. The runtime then records `stopped` in the state so a rebuilt session rests, and saves.

Everything, and staying stopped. The per-person switch acts in three steps (`Halt.stop`, `backend/api/services/chat_session/halt.py`): (1) mark the person stopped, after which the backend neither dials nor mints a delegation for them and their webhooks answer as if they did not exist; (2) kill every chat of theirs with a live delegation, schedule, or open socket, concurrently, allowing ten seconds each; and (3) delete every delegation row. Because a delegation is accepted only while its row exists, a program that ignored its order to end can no longer read a credential, record, or file of the person's: the stop does not depend on anything agreeing to stop. Only the person can resume; the switch action is refused to runtime principals, so what is stopped cannot restart itself.

Rules set beforehand. Each organization has one Safety setting: sites no agent may open, how often agent-written code is put to a person, which packages code may install, whether MCP servers may be added and webhooks received, and whether notifications may carry content or say only that something happened. Each rule is enforced where it can be: blocked sites at the proxy, code rules in the backend as a card opens, the package list in the runtime before a card, MCP and webhooks in the backend.

10.3 The audit trail

Nearly everything the platform lets happen leaves a line in an append-only collection (`AuditStore`, `backend/database/stores/audit.py`), written at chokepoints by two writers (Table 6). The runtime may write only lines of type `execution`, so it cannot forge an approval or a credential read; it does decide whether to write one. "Append-only" is a property of the code, not the database: the store offers `append`, `search` and `for_chat`; nothing calls an update or delete on the collection, and no action exposes one. A line the database refuses twice is written whole to the error log at `CRITICAL`, and the action proceeds: auditing is a witness, not a gate. Each person may read their own trail; the organization's trail is a separate grant.

10.4 The monitoring record

The audit trail says what the platform *allowed*. A second record, kept beside the agents rather than in the database, says what agents' programs *did*: processes started and ended, log lines, and every connection made or refused with host, resolved address, verdict, bytes, and duration—never content. It is a bounded working log (128 MiB, oldest first), readable by administrators through dedicated grants.

Table 6. Audit-trail writers.

Line	Writer and content
`execution`	runtime, per call: agent, function, declared and chat level, outcome, duration, inputs in outline, hosts reached
`approval.requested`, `.resolved`	backend, at the card
`secret.use`, `llm.use`	backend, where a credential or model key is served (reference only)
`agent.*`, `user.*`, `settings.safety`, `work.*`, ...	backend, at each controller
`webhook.received`, `.refused`	backend, at the webhook door (field names, never values)
`platform.action`	gateway: every non-read action outside the chat path, with outcome, never the payload

Table 7. Implementation size (non-test source lines).

Component	Lines
Backend (Python, FastAPI)	29,297
Runtime and agents' container (Python)	18,466
Shared contracts: manifest, package, chat parts (Python)	4,138
Agent SDK (Python, standard library only)	1,543
Spawn helper (C)	934
Web app (TypeScript, Angular; `frontend/src/app`)	33,717

10.5 Notifications out

A person may have their notifications sent to Slack, Teams, or a system of their own. The platform posts a line and a link from a queue, so a slow receiver delays nothing; it never sends a secret or the conversation, and includes the reply text only on request. JSON deliveries are signed with HMAC-SHA256 [5] over `"<timestamp>.<body>"`. An address must be HTTPS and resolve only to public addresses, checked when subscribed and before each send; redirects are not followed.

11 Implementation

DecentAI is open source.[1] It is deployed with Docker Compose as six services: Caddy (the single public entry, also serving the web app), the backend, MongoDB, the runtime, the agents' container, and a speech service. Three networks separate them (Figure 1): `default`, the only one with a route out; `data`, internal, joining only the database, the backend, and a one-shot initializer; and `agents`, internal, joining only the runtime and the agents' container.

Table 7 gives the size of each part. The backend owns identity, policy, the data layer, encryption, OAuth, webhooks, and the audit trail, behind one gateway. The runtime holds the assistant loop (`ai_runtime/mind/`), chat sessions and the clock (`ai_runtime/chat/`), the executor and re-

[1] `https://github.com/decentai-io/decentai`; the public agent catalog is at `https://github.com/decentai-io/decentai-agents`.

Table 8. Automated test suites (test functions; parametrization makes the executed count higher). Results from runs on 15 October 2026.

Suite	Tests	Exercises
Runtime	1,031	assistant loop, executor gates, approvals, clock, stops, proxy, evidence, documentation
Backend	924	identity, policy invariants, delegation fence, data layer and encryption, OAuth, webhooks, audit
Cross-component	180	approval-to-package path; end-to-end chat across backend and runtime
Example agent	24	an agent run as its author would
Total	**2,159**	
of which sandbox, live	83	hostile agent in the deployed two-container topology (Section 12.2)

source mediation (`ai_runtime/execution/`), the worker pool and egress proxy (`ai_runtime/agents/`), and the spawner (`ai_runtime/agents_container/`). Contracts shared by backend and runtime—the manifest validator, the canonical package format, the chat message parts—live in one package so the two sides cannot disagree. Agent code imports only the SDK, which speaks the worker protocol over standard input and output.

Model access goes through connectors for several provider protocols, or a model served on the organization's own machines; the organization configures connections and may scope keys per organization, group, or person. A mobile client (Expo/React Native) is a thin remote control for any instance: chat, approval cards, and notifications.

12 Evaluation

We evaluate whether the mechanisms hold as described, in three ways: automated tests that exercise each promise the way a person, an agent, or an attacker would (Sections 12.1 and 12.2); a structured analysis of what each adversary can reach (Section 12.3); and a check that the documentation this paper is built on matches the code (Section 12.4). We close with what is not evaluated (Section 12.5).

12.1 Test suites

Table 8 summarizes the suites. Runtime tests run real agent code in real processes, with a *scripted model*: a stand-in that returns replies written in advance. This is deliberate. The claims under test concern what the *platform* does with whatever the model proposes (G1), and a test must give the same result on every run. The runtime suite runs against in-memory services that answer the backend's contract; the cross-component suite includes an end-to-end test in which a person's socket reaches the backend, the backend dials a real runtime process, and the runtime calls back through the gateway under the chat's delegation, with nothing stubbed but the model.

Results. On the main branch on 15 October 2026 (Python 3.11, MongoDB 7), every suite passed with no failures: runtime, 1,056 passed and 85 skipped (the 83 live sandbox tests, which need the Linux image and are reported in Section 12.2, and two others); backend, 969 passed and 6 skipped; cross-component, 216 passed and 3 skipped; example agent, 24 passed. Executed counts exceed Table 8 because of parametrization.

Regression tests from review. In October 2026 the entire code base was reviewed line by line. Every case found to make the code fail, hang, or answer wrongly was fixed together with a test that repeats the attempt; in the runtime these are kept in dedicated "edge" files—around stops (26 tests), the executor (17), contracts and the SDK (31), the clock (8), session restarts (6), concurrent stores (8), reasoning budgets (14), and services and connectors (24). Design questions the review raised but did not settle are published with the code (Section 13).

12.2 Confinement against a hostile agent

The way to test a lock is to try to open it. The live sandbox suites (`ai_runtime/tests/test_confinement_live.py`, `test_spawner_live.py`) install a fixture agent that is *hostile on purpose*: each of its functions attempts one escape, and the test passes only when the attempt is refused. Beside each refusal, positive controls check that legitimate work still functions, since a sandbox that refuses everything would pass the first kind of test and fail the second. A second hostile package attacks at *build* time, from a local package index.

Setup. We ran both files in the deployed topology: the runtime's image as the runtime, and again as the agents' container beside it on an internal network, with `NET_ADMIN` for the egress rule. The host kernel was Linux 6.18 (WSL2), which offers every Landlock feature in Table 4, so no test was skipped for want of a kernel feature.

Results. All 83 tests passed and none was skipped (58 confinement tests and 25 tests of the spawner across the two containers; 88 s wall time). Table 9 groups the attempts by the promise they test and the layer that refuses them.

12.3 Security analysis

Table 10 relates each adversary to what it can do and what holds it. Two observations follow. First, the defences against A1 and A2 are the same set of gates, and none of them reads model output: this is what makes the design independent of whether injection is detected. Second, the defences sit in components of different trust: compromising a less trusted component (a worker, then the runtime) leaves in place every defence held by a more trusted one—the backend's keys, its database, its decision on approvals, and its ability to withdraw delegations.

Injection reach by trust level. Because the gate is a single comparison, the reach of a successful injection (A2) inside one chat can be stated exactly: a proposal runs without a card if and only if the function is granted to the chat, its inputs validate, its scopes fit the grant, and $\ell_f \leq \ell_c$. At the default $\ell_c = 1$, an injected proposal can at most read and make ordinary changes through granted agents; every wider change and every action leaving the platform becomes

Table 9. Escape attempts by the hostile agent, each refused, and the legitimate operations verified alongside. All 83 tests passed on Linux 6.18 with no skips.

Promise	Attempts (all refused)	Refused by	Still works
P1 own files	read the runtime's settings; write into its own package, environment, or the install directory; read or write another agent's home or package; read the uid table or the platform's code; write where every user may write	uid ownership; Landlock	reads what it runs from; spool shared with the runtime; home emptied each start, even if closed or deeply nested
P2 own user	signal the runtime; use the spawn helper to become another agent's uid; close or deeply nest its home to keep state across restarts	uid separation; `no_new_privs`; empty capability set; the helper's `clear`	runs as its own uid in its own home; stopping it ends everything it started
P3 declared hosts	connect past the proxy; reach the runtime's own door or the spawner; resolve a name directly; reach an undeclared host; reach anything with `hosts: []` or no network block; reach a blocked site with `hosts: any`	nftables owner rule; proxy; Landlock TCP rule	reaches its declared host; a host its credential names, only for that call; a host a person allowed on a code card, only until the call ends
P4 bounded resources	(verified, not attacked) the worker finds on itself exactly the process, open-file and file-size limits the container set, never a manifest's	`setrlimit`	threads and subprocesses start
P5 system calls	open an unused socket family; `ptrace`; create a namespace; connect to another agent's abstract Unix socket	seccomp; Landlock scoping (ABI 6)	its own Unix socket; a program it runs is fenced with it
Builds	a hostile build reads settings, writes into the environment, reaches hosts other than the index, fetches packages from elsewhere, or never ends	builder uid; proxy pass; five-minute kill	wheels built and installed by the runtime; only wheels are left
Records	an agent reads the monitoring record	folder mode and Landlock	both containers write one record

a card. At $\ell_c = 0$, only reads run unasked. At $\ell_c = 3$, every granted function runs unasked—the case the trust level exists to make a person's explicit choice. In every case, egress remains restricted to declared hosts and no credential is exposed to the model.

Blast radius. A compromised worker holds what its call was handed, its own home, and its declared hosts. A compromised runtime can act for the people whose delegations it holds—people with a chat open or a schedule running—within 40 actions, and, since the level gate runs in the runtime, could run their granted functions without opening a card; it cannot answer a card, read the database, open a sealed value, obtain a refresh token, or act for anyone else. Delegations last at most an hour and are withdrawn by the person's stop-everything switch. A compromised backend is a compromise of the deployment; it is the one component trusted with everything.

12.4 Documentation held to the code

This paper is distilled from the project's documentation, which names the files implementing each mechanism. Five tests hold that documentation to the code: every relative link and heading anchor resolves; every backticked repository path exists; every setting the configuration page describes is read by code, and every setting the example files offer is documented; and the published list of actions is regenerated from the backend's catalog and must match. These tests check what a page *points at*; whether a sentence is true is for a reader to verify, which is why each mechanism here names its file.

12.5 What is not evaluated

- **Model behaviour.** No test calls a real model. The tests show that a proposal cannot pass the gates; they do not measure whether a given model resists injected text or chooses well. Neither is a claim of this paper.
- **Performance and scale.** We do not report latency or throughput overheads, nor behaviour with many organizations, chats, or concurrent fires.
- **The kernel.** Confinement results hold on the kernel tested; a kernel flaw is a way past every layer, and no test rules one out.
- **The web app's own tests** exist but were not part of this evaluation.

13 Limitations

A security paper that lists only what works asks to be taken on faith. We classify each known limit as *chosen* (a trade-off made on purpose), *open* (raised by the October 2026 code review and not yet decided; 137 such questions are published with the code, each naming its file), or *inherited* from the environment.

The model. The platform does not make the model correct (*chosen*). A yes is only as good as the reading of the card. Injection still steers what runs without a card at or below the chat's level, all granted functions at level 3; there is deliberately no administrator ceiling on the level (*chosen*). A plan item counts as "verified" when it has *some* evidence:

Table 10. Adversaries, their capabilities, and the mechanisms that hold them.

Adversary	Can	Held by
A1 model	emit any action in the vocabulary, with any inputs; write any prose	every action validated and gated outside the model; grants deny by default; the level gate; evidence drawn only from the trace
A2 injector	choose text the model reads, and so steer its proposals	the same gates; none of grants, level, manifest hosts, approval hash or credential binding derives from model output; a denial refuses the named hosts to the whole agent for the rest of the request
A3 agent author	arbitrary code in the worker during a call	approval pinned to commit and digest; per-operation resource mediation; uid, Landlock, seccomp, limits; egress only to declared hosts; dependencies built by a separate confined user
A4 another person	their own session, cookie, or API key	sessions resolved per request; deny-by-default policy; reads filtered by visibility inside the query; tenant scoping; `Origin` check on cookie-bearing sockets
A5 compromised worker	the above, plus attacks on co-tenants of the container	sandbox layers; internal network leading only to the runtime
A6 compromised runtime	every delegation it currently holds	no database route, decryption key, or backend signing key; 40-action fence; cannot decide approvals; stop-everything withdraws its delegations

one successful call attaches to every active item, and the model chooses which reference it cites (*open*).

Agents and the sandbox. An agent can misuse what it was rightly given: during a call it holds the decrypted credential and may talk to its declared host, and the proxy sees host and byte counts, never content (*chosen*: reading inside TLS would mean impersonating every site). Because workers are kept warm, code that wants to could retain a credential beyond the call—an OAuth access token until it expires, a typed key until it is changed (*chosen*; review before approval is the control). A Google token carries every scope the catalog's Google agents share; what keeps the Gmail agent to mail is its single declared host. The kernel is shared by all containers (*inherited*); the seccomp filter exists only on x86-64 and arm64, and a deployment whose agents need a refused call can switch it off—for every agent at once—both stated at start. Two colluding agents can exchange bytes through a file in `/tmp` or `/dev/shm` on any kernel (*open*), or through an abstract socket before Linux 6.12 (*inherited*). Once connected to a declared address, an agent can ask that address for another site it serves (*open*). Memory is a shared pool sampled once a second, and disk use is counted but not capped (*chosen*).

People and organizations. The sandbox separates agents, not the people who use one: one worker per approved agent serves everyone in the organization granted it, so its memory and a host lent for one person's call are shared with a concurrent colleague's call (*chosen*, for memory and start-up cost). Tenants share the agents' container, so process listings and the connection log span organizations, and an agent writing enough to its error output can push others' connection records out of the bounded log (*open*); the audit trail is a separate store and unaffected. A compromised runtime can act, within 40 actions and without opening cards, for people whose delegations it holds (*chosen*: a scheduled chat must act while its person is away).

Data and records. The audit trail is append-only by the code's shape, not by the database: an operator with the database password could alter it undetectably, as there is no hash chain (*chosen*, consistent with the out-of-scope operator). A call's inputs are recorded in outline as proposed, so a password a person typed into the chat and the model passed on, or a secret an agent placed in its error text, can reach the trail (*open*). An agent that returns a credential in its result passes it to the model and the trail: results are validated for shape, not scanned for secrets. File bytes are not sealed by the platform; they rest on the backend's volume or in a cloud bucket encrypted by its provider.

Webhooks. Only DecentAI's own signature scheme is verified; providers with their own schemes are reached through a relay. The rate limit is counted per backend process. An outbound address is checked by name and then connected to by name, leaving a DNS-rebinding window (*open*). An event the chat could not receive is marked undelivered and not retried.

Operation. One runtime serves a deployment, and nothing moves a chat between runtimes (*chosen*). A stop sent while a new message is being prepared, which may include installing an agent, waits until that preparation finishes; the per-person switch does not, since it withdraws every delegation (*open*). A one-off reminder whose fire fails is spent without notice (*open*). Agent code that writes to standard output corrupts its own protocol line, and one blocking call stalls a worker's other calls (*open*); a broken worker fails honestly and the next call starts a fresh one.

14 Conclusion

DecentAI takes the language model as it is—capable, fallible, and steerable by what it reads—and builds around it a platform in which the model holds no authority. Every proposed action meets gates whose inputs are identity, grants, a person-chosen trust level, an agent's approved manifest, and the person's approval of the exact call; none is derived from model output. Untrusted agent code runs as its own user, fenced by Landlock and seccomp, reaching only declared hosts through a proxy, with credentials lent per call and never shown to the model. What appears as data beside the model's words is drawn from stored, validated results. A stop withdraws the keys rather than asking for cooperation, and an append-only trail records what was allowed.

None of these mechanisms is new on its own; they are the protections operating systems have offered programs for half a century. The contribution is to place them around a planner that is very capable and not trusted, so that when it is wrong—and it will be—the mistake is contained to what a person could already do, visible on a card or in a record, and stoppable. The implementation is open, the tests that hold its claims can be rerun by anyone, and the limits are stated beside them.

Acknowledgements

AI tools (Claude, by Anthropic) assisted in drafting the text of this paper and in checking its claims against the source code. The author reviewed the text and is responsible for its content.

Availability

The source code, documentation, and test suites are available at `https://github.com/decentai-io/decentai`; the agent catalog used in the examples is at `https://github.com/decentai-io/decentai-agents`.

References

[1] James P. Anderson. Computer security technology planning study. Technical Report ESD-TR-73-51, Electronic Systems Division, Air Force Systems Command, 1972.

[2] Morris Dworkin. Recommendation for block cipher modes of operation: Galois/Counter Mode (GCM) and GMAC. Technical Report SP 800-38D, National Institute of Standards and Technology, 2007.

[3] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. In *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (AISec)*, pages 79–90, 2023. doi: 10.1145/3605764.3623985.

[4] Dick Hardt. The OAuth 2.0 authorization framework. RFC 6749, 2012.

[5] Hugo Krawczyk, Mihir Bellare, and Ran Canetti. HMAC: Keyed-hashing for message authentication. RFC 2104, 1997.

[6] Fábio Perez and Ian Ribeiro. Ignore previous prompt: Attack techniques for language models. arXiv:2211.09527, 2022.

[7] Nat Sakimura, John Bradley, and Naveen Agarwal. Proof key for code exchange by OAuth public clients. RFC 7636, 2015.

[8] Jerome H. Saltzer and Michael D. Schroeder. The protection of information in computer systems. *Proceedings of the IEEE*, 63(9):1278–1308, 1975. doi: 10.1109/PROC.1975.9939.

[9] The Linux kernel documentation. Landlock: unprivileged access control. `https://docs.kernel.org/userspace-api/landlock.html`, accessed October 2026, .

[10] The Linux kernel documentation. Seccomp BPF (secure computing with filters). `https://docs.kernel.org/userspace-api/seccomp_filter.html`, accessed October 2026, .